

CONTRATO DE PRESTACIÓN DE SERVICIOS DE PENTESTING Y EVALUACIONES DE VULNERABILIDADES

Entre las partes: **Global Security Testing**, cédula jurídica: **3-102-884120**, en adelante denominada el **CONSULTOR**. **NOVASHOP S.A.**, cédula jurídica: **3-101-728495**, representado legalmente por Armando Méndez Madrigal, en adelante denominada el **CLIENTE**.

CLÁUSULA PRIMERA: OBJETO DEL CONTRATO

El **CONSULTOR** realizará una evaluación de seguridad técnica integral que comprende la identificación de vulnerabilidades en la infraestructura lógica y la ejecución de pruebas de penetración (Pentesting) dirigidas a la aplicación web pública de NOVASHOP S.A. El objetivo es diagnosticar el estado de seguridad del entorno para construir una Matriz de Vulnerabilidades y validar la resiliencia de los activos críticos frente a ciberataques.

CLÁUSULA SEGUNDA: ALCANCE Y LIMITACIONES

El servicio se divide en dos fases técnicas complementarias:

- **Fase de Diagnóstico de Infraestructura:** Revisión técnica y escaneo de los activos que soportan la aplicación web. Esta fase es indispensable para la identificación de Vulnerabilidades y el diseño de escenarios de ataque de la prueba de penetración (pentesting). Incluye la validación de puertos, servicios, versiones de software y configuraciones de red lógica.
- **Fase de Ejecución (Pentesting):** El esfuerzo de explotación se centrará exclusivamente en la aplicación web pública (autenticación, gestión de pedidos y transacciones), utilizando los hallazgos de la fase de diagnóstico para simular vectores de ataque reales.

Exclusión: Se excluye explícitamente la infraestructura física (hardware, cableado, acceso a instalaciones) y la explotación de vulnerabilidades en activos de la nube que no tengan relación directa con el flujo de la aplicación web.

CLÁUSULA TERCERA: EXCLUSIONES ÉTICAS Y LIMITACIONES TÉCNICAS

- **Identificación vs. Explotación:** En la infraestructura, el **CONSULTOR** se limitará a identificar y reportar vulnerabilidades. La fase de explotación destructiva queda restringida para evitar impactos en la continuidad operativa de la empresa .
- **Disponibilidad:** Se analizará la susceptibilidad a ataques de denegación de servicio (DoS), ataques de inyección (SQL) a nivel de aplicación (Capa 7), evitando acciones que degraden el servicio al usuario final.

CLÁUSULA CUARTA: LIMITACIÓN DE RESPONSABILIDAD

- **Estado Preexistente:** El **CONSULTOR** no será responsable por fallas, interrupciones o daños en componentes de hardware (fuentes de poder, discos duros, tarjetas de red) que presenten un estado de deterioro previo, obsolescencia o fatiga de material al momento de iniciar los escaneos de red.
- **Continuidad en Equipos Críticos:** El **CLIENTE** reconoce que el proceso de auditoría somete a los activos a un tráfico de red controlado; si un equipo de infraestructura (como los servidores mencionados en el alcance) falla debido a su ciclo de vida agotado o falta de mantenimiento preventivo, dicha falla no será imputable al **CONSULTOR**.
- **Respaldo:** El **CLIENTE** garantiza que posee respaldos de seguridad vigentes antes del inicio de las actividades, de lo contrario el **CLIENTE** mantendrá al **CONSULTOR** libre de toda responsabilidad y reclamo por daños indirectos, pérdida de datos (si no existiera respaldo previo por parte del **CLIENTE**)

CLÁUSULA QUINTA: METODOLOGÍA

El servicio seguirá el estándar de ejecución de pruebas de seguridad:

- **Reconocimiento e Identificación:** Mapeo de la infraestructura lógica para la Matriz de Vulnerabilidades.
- **Modelado de Amenazas:** Definición de escenarios de pentesting basados en los hallazgos previos.
- **Explotación Controlada:** Pruebas enfocadas en la aplicación web.

CLÁUSULA SEXTA: ENTREGABLES

1. **Reporte Técnico :** Inventario técnico de debilidades en la infraestructura y servicios y su respectivo plan de mitigación, este informe será detallado para el área de administración de red.
2. **Matriz de Evaluación de Vulnerabilidades:** Clasificación de riesgos (Crítico, Alto, Medio, Bajo).
3. **Reporte Ejecutivo:** Resumen de alto nivel para la dirección sobre la postura de riesgo y continuidad, resultados finales del pentesting y plan de mitigación .

CLÁUSULA SÉPTIMA: CONFIDENCIALIDAD

Toda la información recolectada durante el diagnóstico y la explotación es **estrictamente Confidencial** y propiedad del **CLIENTE**. Toda la información obtenida durante la auditoría, como topologías, contraseñas identificadas, vulnerabilidades y datos de empleados, por lo que el **CONSULTOR** no podrá divulgar estos datos a terceros y los eliminará al finalizar el proyecto, salvo los reportes entregados al **CLIENTE**.

CLÁUSULA OCTAVA: RESPONSABILIDADES DEL CLIENTE

El **CLIENTE** facilitará el acceso lógico,proporciona acceso a la documentación de red y al personal técnico de apoyo. necesario para que el **CONSULTOR** realice la identificación de vulnerabilidades en la infraestructura y las pruebas en la aplicación web.

CLÁUSULA NOVENA: DURACIÓN Y HONORARIOS

- **Duración:**La duración estimada del proyecto será de un mes calendario, iniciando formalmente tras la entrega de los accesos técnicos por parte del **CLIENTE**.Este tiempo puede variar si hay atrasos en la entrega de accesos.
- **Valor del contrato: \$5,500 + 13% IVA (\$715).** Monto total: **\$6,215.**
- **Forma de pago:** 30% a la firma, 40% tras el reporte preliminar de hallazgos, 30% contra entrega final.

CLÁUSULA DÉCIMA: RESGUARDO Y DESTRUCCIÓN DE DATOS

El **CONSULTOR** mantendrá una copia cifrada de los entregables por un plazo máximo de 30 días naturales ,tras la entrega final , con el único fin de brindar soporte técnico, tras el cual procederá a la destrucción segura, definitiva e irrecuperable de toda la evidencia técnica recolectada,incluyendo capturas de pantalla, logs de escaneo, tráfico de red, listas de activos, topologías, credenciales y scripts personalizados, en cualquier medio de almacenamiento físico o en la nube; esta eliminación será validada mediante una Certificación de Borrado formal enviada al **CLIENTE**, exceptuando únicamente las metodologías y plantillas de reporte preexistentes, siempre que estas no contengan datos que permitan identificar la infraestructura o vulnerabilidades específicas de NOVASHOP S.A.

FIRMAS

En señal de conformidad, las partes firman en dos tantos de un mismo tenor, en la ciudad de San José, Costa Rica, a los _____ días del mes de _____ de 2026.

Por el CONSULTOR (Global Security Testing)	Por el CLIENTE (NOVASHOP S.A.)
	
Firma Autorizada	Lic. Armando Méndez Madrigal
Cédula: <u>3-0555-0002</u>	Cédula: <u>1-1234-0567</u>
Cargo: Cybersecurity Lead	Cargo: Director de Tecnología (CTO)

